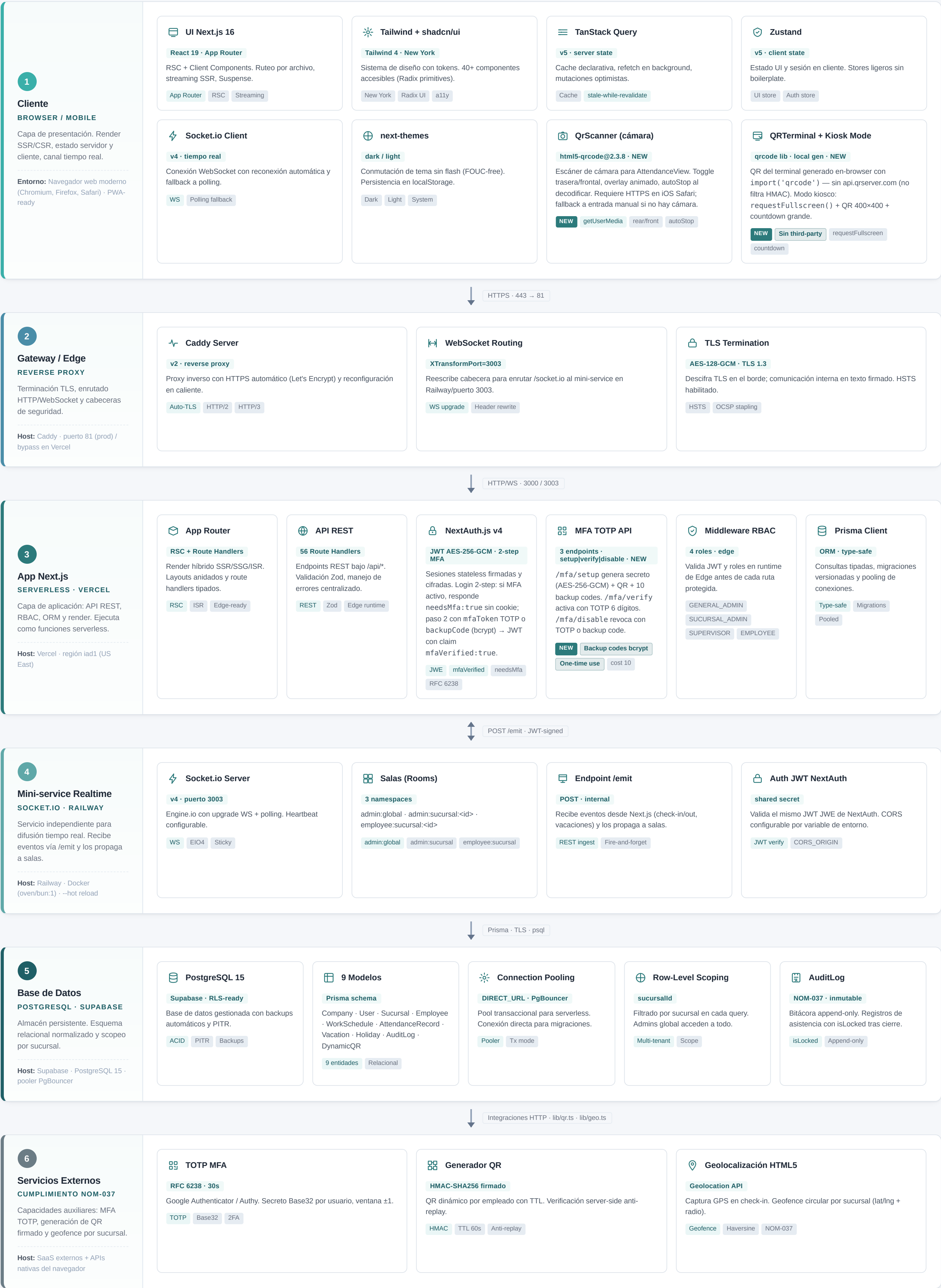


Control de Asistencia NOM-037 — Arquitectura del Sistema

Vista de capas técnica del stack en producción (Next.js 16 · Prisma · PostgreSQL · Socket.io) con gateway Caddy, mini-service realtime en Railway y servicios externos de cumplimiento normativo (MFA TOTP, QR HMAC, geolocalización).
Rev. 2 — incorpora flujo MFA 2-step con backup codes, escáner de cámara QR (html5-qrcode) y generación local de QR (sin servicios de terceros).

Repo: github.com/moygallegru/trujillo-stack/control-de-asistencia
Deploy: [control-asistencia-v22.vercel.app](#)
Rev: 2 — post-MFA & QR scanner impl



4

Mini-service Realtime
SOCKET.IO · RAILWAY

Servicio independiente para difusión tiempo real. Recibe eventos vía /emit y los propaga a salas.

Host: Railway · Docker (oven/bun:1) · --hot reload

Socket.io Server

v4 · puerto 3003

Engine.io con upgrade WS + polling. Heartbeat configurable.

WS · EIO4 · Sticky

Salas (Rooms)

3 namespaces

admin:global · admin:sucursal:<id> · employee:sucursal:<id>

admin:global · admin:sucursal · employee:sucursal

Endpoint /emit

POST · internal

Recibe eventos desde Next.js (check-in/out, vacaciones) y los propaga a salas.

REST ingest · Fire-and-forget

Auth JWT NextAuth

shared secret

Valida el mismo JWT JWE de NextAuth. CORS configurable por variable de entorno.

JWT verify · CORS_ORIGIN

5

Base de Datos
POSTGRESQL · SUPABASE

Almacén persistente. Esquema relacional normalizado y scopeo por sucursal.

Host: Supabase · PostgreSQL 15 · pooler PgBouncer

PostgreSQL 15

Supabase · RLS-ready

Base de datos gestionada con backups automáticos y PITR.

ACID · PITR · Backups

9 Modelos

Prisma schema

Company · User · Sucursal · Employee · WorkSchedule · AttendanceRecord · Vacation · Holiday · AuditLog · DynamicQR

9 entidades · Relacional

Connection Pooling

DIRECT_URL · PgBouncer

Pool transaccional para serverless. Conexión directa para migraciones.

Pooler · Tx mode

Row-Level Scoping

sucursallid

Filtrado por sucursal en cada query. Admins global acceden a todo.

Multi-tenant · Scope

AuditLog

NOM-037 · immutable

Bitácora append-only. Registros de asistencia con isLocked tras cierre.

isLocked · Append-only

6

Servicios Externos
CUMPLIMIENTO NOM-037

Capacidades auxiliares: MFA TOTP, generación de QR firmado y geofence por sucursal.

Host: SaaS externos + APIs nativas del navegador

TOTP MFA

RFC 6238 · 30s

Google Authenticator / Authy. Secreto Base32 por usuario, ventana ±1.

TOTP · Base32 · 2FA

Generador QR

HMAC-SHA256 firmado

QR dinámico por empleado con TTL. Verificación server-side anti-replay.

HMAC · TTL 60s · Anti-replay

Geolocalización HTML5

Geolocation API

Captura GPS en check-in. Geofence circular por sucursal (lat/lng + radio).

Geofence · Haversine · NOM-037

